Community Tech Aid Security Policy Manual

Organization: eBiz Market, LLC (Idaho), operating as Community Tech Aid (CTA)
System: Community Tech Aid, a consumer AI tech-support web application (https://communitytechaid.ai)
Framework: NIST SP 800-53 Revision 5, LOW baseline
Designated official: the Owner and sole principal of eBiz Market, LLC
Version: 1.0
Effective date: 2026-07-27
Review cadence: at least annually, and following any significant change to the system

About This Manual

This manual is the policy and procedure set for Community Tech Aid. It contains one policy per applicable NIST SP 800-53 Rev 5 control family and satisfies the family "-1" (Policy and Procedures) control for each. It is a companion to the System Security Plan (the communitytechaid.ai NIST 800-53 Rev 5 LOW control statements), which records how each control is implemented and where the gaps are. This manual states the standing rules; the System Security Plan records the current state against them.

It is written for the actual organization: a single-owner Idaho limited liability company with no employees, no contractors, and no separate staff. Where a control family requires roles, all roles are held by the Owner, and the manual says so rather than inventing a structure that does not exist. The point of a policy manual for a business this size is not to simulate a large security organization. It is to state clearly what the one accountable person is committed to doing, to make those commitments auditable, and to be honest about the boundaries of what a single operator on a managed platform can control.

The following conventions apply throughout and are stated once here rather than repeated in every policy.

Designated official. The Owner is the designated official responsible for developing, documenting, disseminating, maintaining, and enforcing every policy in this manual. Because the Owner is the only member of the workforce, dissemination and acknowledgment are inherent: there is no separate audience to distribute to, and the act of authoring and adopting this manual is the act of dissemination.

Management commitment. The Owner is the management of the business and commits the funds, time, and attention needed to operate the controls described here. Adopting and maintaining this manual, and funding the platforms and services the controls depend on, is the expression of that commitment.

Coordination among organizational entities. There are no internal entities to coordinate. Coordination is external, with the service providers the system depends on: the application build and hosting platform, the managed backend platform, the edge and DNS provider, the payment processor, the AI inference provider, and the transactional email provider. Where a policy depends on a provider, the policy names the coordination point and states what the provider is relied on to do.

Compliance. The Owner monitors compliance with each policy through direct operation of the system. Deviations and known gaps are recorded in the System Security Plan rather than hidden. Compliance for this business is a matter of the Owner holding the Owner accountable to the stated rules and recording honestly where the system does not yet meet them.

Review and update. The Owner reviews and updates each policy and its procedures at least annually and following any significant change to the system. A significant change includes a change of provider, the addition or removal of a data type, a material change to the authorization boundary, the addition of any person other than the Owner to an administrative role, or a security incident. This manual records the review cadence and triggers; it does not claim that a review has already occurred beyond the initial authoring on the effective date above.

Administrative account security. Multifactor authentication is enabled on all administrative provider accounts. This manual does not map any specific control state to any named vendor console.

Inherited controls. The system runs on managed platforms. Where a control is delivered wholly or partly by a provider, the policy states the inheritance position and describes the Owner's residual responsibility rather than claiming the Owner performs work the provider actually performs.

Honesty over coverage. These policies describe what the system actually does. Where a practice is not yet in place, the policy states that plainly and identifies it as a gap tracked in the System Security Plan. No policy claims a capability the system does not have.

AC - Access Control Policy

Purpose and Scope

This policy governs how access to Community Tech Aid and its data is granted, enforced, restricted, and reviewed. It covers three kinds of access: end-user access to the application, administrative access to the platforms that build, host, and operate the system, and the logical access controls applied to data stored in the database. It applies across the entire authorization boundary defined in the System Security Plan, including the frontend, the edge functions, and the application database. It does not attempt to govern the internal access controls of the managed platforms themselves, which are the providers' responsibility and are addressed as inherited controls.

Authority, Management Commitment, and Designated Official

The Owner is the designated official for this policy and commits to operating and funding the access controls it describes. The Owner is the single authorizing authority for all access decisions.

Roles and Responsibilities

The Owner performs every access control function: provisioning and de-provisioning access, defining and maintaining the access enforcement logic in the application, holding and protecting the sole set of administrative credentials, and deciding what content is public. There are no other account administrators, no delegated approvers, and no separation-of-duties scheme, because there is one accountable person. The end user is responsible only for the security of their own account credentials.

Policy Statements

Access to gated functionality requires an authenticated account. Anonymous sign-in is disabled, and no gated action is permitted without identification and

authentication. Access to paid functionality is granted only through conditions that are validated on the server: an active, non-expired plan, an account within the free-message allowance, or a legacy paid token that is validated server-side. Authorization is never decided by client-held state alone. Access to stored data is restricted so that each authenticated user can reach only their own records, enforced at the database layer through Row Level Security rather than in application code alone. Administrative access to the platforms that operate the system is limited to the Owner, protected by multifactor authentication on all administrative provider accounts, and never shared. Public content is limited to a defined set of unauthenticated pages, and no user-generated content is published to public pages. Sessions end after a defined period of inactivity, requiring re-authentication.

Procedures

When a user requests paid features, the application checks plan status, the free-message counter, or a server-validated legacy token before admitting the user to the chat and triage surfaces. The free-message allowance is checked on the server before any paid downstream call is made. Data access is constrained continuously by Row Level Security policies attached to the application tables. Idle timeouts sign the user out on both the authenticated general routes and the chat surface and require re-authentication. When the Owner grants administrative access to a provider console, the Owner confirms multifactor authentication is enabled on that account.

Control Family Coverage

This policy governs the LOW-baseline access controls as follows. Account management (AC-2) is handled through the managed authentication service with a signup trigger and a separate roles table. Access enforcement (AC-3) is delivered by Row Level Security and the server-side access gate. Unsuccessful logon handling (AC-7) relies on the authentication service's throttling, with failure events logged by the application. System use notification (AC-8) is not implemented and is recorded as a gap. Permitted actions without authentication (AC-14) are limited to viewing public pages. Remote access (AC-17) is inherent to a web application and is protected by transport encryption and administrative multifactor authentication. Wireless access (AC-18) and mobile device control (AC-19) are not applicable because the organization operates neither. Use of external systems (AC-20) is governed by documenting each integration and its data exchange. Publicly accessible content (AC-22) is authored and posted only by the Owner.

Known Limitations

The application does not present a system-use notification banner at login, and account lockout thresholds for failed logins are set by the managed authentication service and cannot be configured by the Owner. Both are recorded in the System Security Plan.

Coordination, Compliance, and Review

Access control depends on the managed authentication service and the edge provider, which are the external coordination points. The Owner monitors compliance by operating the access paths directly and reviewing the small set of accounts. This policy is reviewed at least annually and after any significant change to authentication, authorization, the public page set, or the set of administrative accounts.

AT - Awareness and Training Policy

Purpose and Scope

This policy governs security awareness and training for the Community Tech Aid workforce. It applies to every person who operates or maintains the system. Its scope is deliberately matched to the size of the organization.

Authority, Management Commitment, and Designated Official

The Owner is the designated official for this policy and commits to maintaining the security competence that operating the system safely requires.

Roles and Responsibilities

The workforce is one person, the Owner, who is a practicing technician. The Owner is responsible for maintaining their own awareness of the security topics relevant to the system. There is no training coordinator, no curriculum, and no trainee population, because there is no second person.

Policy Statements

Because eBiz Market, LLC has no employees or contractors, no formal workforce awareness program and no role-based training program are maintained, and this policy does not pretend otherwise. The Owner remains responsible for staying current on the security topics that bear directly on the system, including secure authentication and session practices, common web application weaknesses such as broken access control and injection, safe handling of secrets and API keys, and the security characteristics and shared-responsibility boundaries of the managed providers the system depends on. Competence is demonstrated in the build rather than in a training log, for example through the breached-password check enforced at registration and the same-day correction of a client-side trust weakness recorded in the System Security Plan.

Procedures

The Owner maintains awareness through provider security notifications, published security guidance and advisories, and direct review of the system's own code and configuration. There is no training roster, course catalog, or completion tracking, because there is no one to enroll or track.

Control Family Coverage

This policy governs the LOW-baseline awareness and training controls as follows. Literacy training and awareness (AT-2) is met by the Owner's self-directed competence rather than a program and is marked not applicable as a workforce activity. Role-based training (AT-3) is not applicable because there are no separate roles to train. Training records (AT-4) are not maintained because there is no workforce to record. If the business ever adds staff, each of these becomes a real obligation and this policy must be rewritten.

Known Limitations

There is no formal, evidenced training program. For a single-operator business this is a scope decision rather than a deficiency, but it is stated plainly so a reader is not left to assume a program exists.

Coordination, Compliance, and Review

There are no internal entities to coordinate. Compliance is self-directed. This policy is reviewed at least annually and immediately if the business adds any

person to the workforce, at which point a real awareness and role-based training program and training records become necessary.

AU - Audit and Accountability Policy

Purpose and Scope

This policy governs what events Community Tech Aid logs, how audit records are generated, protected, retained, and reviewed, and how accountability for actions is established. It covers the audit records the application generates itself and the platform logs the system inherits from the managed backend and the edge provider. It applies to the whole authorization boundary.

Authority, Management Commitment, and Designated Official

The Owner is the designated official for this policy, defines the application-level events that are logged, and commits to maintaining the logging functions and the retention job.

Roles and Responsibilities

The Owner is the sole reviewer of audit data and the only person who can change what the application logs. Platform log generation, storage, and time stamping are the responsibility of the managed providers.

Policy Statements

The system records security-relevant authentication events, specifically account signup, successful login, failed login, and logout, each with the source IP address of the request taken from the forwarded-for header. Application analytics events are recorded through a dedicated function that accepts requests only from an explicit list of allowed origins rather than a wildcard. Authentication event records are retained for 90 days and then purged automatically by a scheduled database job. Audit data stored in the database is protected by the same Row Level Security and managed-platform access model that protects all application data. Time stamps for records are supplied by the managed platform. The Owner does not have direct database access outside the managed platform, which both limits tampering and limits the Owner's ability to independently inspect raw platform logs.

Procedures

Authentication events are written by a dedicated logging function as they occur. A scheduled database job removes authentication events older than 90 days. Analytics events are written by the analytics function, which rejects disallowed origins and fails without blocking the user. Platform logs for the database and the edge functions are generated and retained by the providers under their defaults.

Control Family Coverage

This policy governs the LOW-baseline audit controls as follows. Event logging (AU-2) covers the defined authentication and analytics events plus inherited platform logging. Content of audit records (AU-3) includes event type, source IP, timestamp, and user association for application records, with platform record content set by the provider. Storage capacity (AU-4) is a platform responsibility, bounded on the application side by the 90-day purge. Response to logging failures (AU-5) is not implemented and is recorded as a gap. Review and analysis (AU-6) is not performed on a schedule and is recorded as a gap. Time stamps (AU-8) are inherited. Protection of audit information (AU-9) uses Row Level Security and the managed access model. Retention (AU-11) is 90 days for application authentication events and provider-set for platform logs. Audit record generation (AU-12) is performed by the application logging functions and the platform.

Inherited Responsibilities

Platform log content, storage capacity, time source, and platform-level log protection are provided by the managed backend and edge providers and cannot be configured by the Owner.

Known Limitations

Non-blocking email alerting now fires on edge-function logging errors and on a defined login-failure pattern (five or more failures from one IP within 15 minutes), so the logging pipeline is no longer silent on those triggers. A scheduled, documented human review of audit records is still not performed. These limitations are recorded in the System Security Plan.

Coordination, Compliance, and Review

Audit capability is shared with the managed backend and edge providers, which supply platform logging, storage, and time stamps. The Owner monitors compliance by querying the application audit tables. This policy is reviewed at least annually and after any change to the logging functions or the retention job.

CA - Assessment, Authorization, and Monitoring Policy

Purpose and Scope

This policy governs how the security posture of Community Tech Aid is assessed, how the system is authorized to operate, how interconnections with external services are documented and authorized, and how the system is monitored on an ongoing basis. It applies to the whole authorization boundary and to the external interconnections named in the System Security Plan.

Authority, Management Commitment, and Designated Official

The Owner is the designated official for this policy and is both the assessor and the authorizing party. There is no external authorizing official, because this is a private commercial system with no regulatory authorization requirement identified.

Roles and Responsibilities

The Owner performs the self-assessment, accepts residual risk, documents interconnections, and maintains the gap register. There is no independent assessor and no separate authorization board.

Policy Statements

The security posture of the system is assessed by the Owner through the control review captured in the System Security Plan, which is maintained as the

system changes. The Owner is the accountable authorizing party and formally accepts the residual risk documented in that plan. Interconnections with external services, including the AI inference provider, the payment processor, the transactional email provider, the edge and DNS provider, and the external support and training channels, are documented in the System Security Plan together with the data each exchange carries. Open weaknesses are tracked in the Known Gaps section of the System Security Plan, which serves as the plan of action.

Procedures

The Owner reviews the control set and updates the System Security Plan when the system changes. Interconnections are recorded in the boundary and data-flow sections of that plan. Continuous monitoring uses the telemetry available from the edge provider and the application analytics and authentication tables.

Control Family Coverage

This policy governs the LOW-baseline assessment and monitoring controls as follows. Control assessments (CA-2) are self-performed through the System Security Plan. Information exchange (CA-3) is governed by documenting and authorizing each interconnection. Plan of action and milestones (CA-5) is the gap register, which lacks dated milestones and is recorded as a gap. Authorization (CA-6) rests with the Owner as the accountable party. Continuous monitoring (CA-7) is limited to available telemetry with no defined strategy, and is recorded as a gap. Internal system connections (CA-9) inside the managed platform are authorized at the data layer by Row Level Security and otherwise inherited.

Known Limitations

Assessments are self-performed with no independent assessor. The plan of action records weaknesses but does not assign dated remediation milestones. Continuous monitoring has no defined strategy, metrics, or alerting beyond raw telemetry. These are recorded in the System Security Plan.

Coordination, Compliance, and Review

Monitoring telemetry is shared with the edge provider. The Owner monitors compliance by maintaining the System Security Plan. This policy is reviewed at least annually and after any significant change to the boundary or the set of interconnections.

CM - Configuration Management Policy

Purpose and Scope

This policy governs how the configuration of Community Tech Aid is established, changed, restricted, and inventoried. It covers the application, its edge functions, its database schema, the security-relevant settings the Owner controls, and the inventory of components and providers. It applies to the whole authorization boundary.

Authority, Management Commitment, and Designated Official

The Owner is the designated official for this policy and is the only person able to change the system.

Roles and Responsibilities

The Owner makes all configuration decisions and holds the sole change authority. Runtime configuration of the managed platform is the responsibility of the backend provider.

Policy Statements

The ability to change the system is restricted to the Owner through authenticated access to the management consoles, with multifactor authentication enabled on all administrative provider accounts. Security-relevant settings that the Owner controls are maintained in a known-good state: anonymous sign-in is disabled, the authentication redirect allowlist contains only intended entries with no open wildcards, the analytics function accepts only allowed origins, and Row Level Security is enabled on application tables. Application secrets, including the AI provider API key, are stored in the platform secret store and never placed in client code. The system exposes only the functionality required for its service. The system inventory is the component list in the System Security Plan, covering the frontend, the edge functions, the database tables, the providers, the domains, and the external interconnections.

Procedures

Changes are made by the Owner directly in the build environment. When a change touches a security-relevant setting, the Owner verifies that setting against the known-good state described above. The component inventory in the System Security Plan is updated when components are added or removed.

Control Family Coverage

This policy governs the LOW-baseline configuration controls as follows. Baseline configuration (CM-2) is the current documented state of the project and provider settings; a separately versioned baseline document is not maintained and is recorded as a gap. Impact analysis (CM-4) is not performed as a formal step and is recorded as a gap. Access restrictions for change (CM-5) limit change authority to the Owner under multifactor authentication. Configuration settings (CM-6) covers the known-good security settings the Owner controls. Least functionality (CM-7) limits exposed functions and flags an unused edge worker for confirmation. Component inventory (CM-8) is the System Security Plan component list. Software usage restrictions (CM-10) and user-installed software (CM-11) are met by using licensed managed components and by allowing no user-side software installation.

Inherited Responsibilities

Runtime configuration and patching of the managed platform are performed by the backend provider and are not owner-configurable.

Known Limitations

There is no separately captured, versioned configuration baseline document and no formal security impact analysis step before a change. Two inventory items are unconfirmed and tracked as owner input: a seventh provider-account domain and an edge worker with no recorded invocations. These are recorded in the System Security Plan.

Coordination, Compliance, and Review

Runtime configuration is inherited from the backend provider. The Owner monitors compliance by operating the build environment and provider consoles. This policy is reviewed at least annually and after any significant configuration change.

CP - Contingency Planning Policy

Purpose and Scope

This policy governs how Community Tech Aid prepares for and recovers from disruption, including data backup, system recovery, and the availability of the service. It applies to the whole authorization boundary and reflects the system's dependence on managed platforms for availability.

Authority, Management Commitment, and Designated Official

The Owner is the designated official for this policy and is responsible for contingency preparation and for any recovery action within the Owner's control.

Roles and Responsibilities

The Owner is responsible for confirming that platform backups exist and for any application-level recovery. Availability, redundancy, and recovery of the compute and database tiers are the responsibility of the managed backend and edge providers.

Policy Statements

The system relies on the availability, redundancy, and recovery capabilities of the managed backend platform and the edge provider for the compute, storage, and database tiers. Database backups are provided by the managed backend platform and are visible to the Owner in the platform database view. The Owner treats the provider platforms as the primary source of recovery for the data and compute tiers, and maintains the ability to rebuild the application from the build environment and provider consoles.

Procedures

The Owner confirms that platform-provided backups are present through the platform database view. Recovery of the application, if required, is performed through the build environment and the provider consoles.

Control Family Coverage

This policy governs the LOW-baseline contingency controls as follows. Contingency plan (CP-2) is not maintained as a written plan with defined recovery objectives, roles, and steps, and is recorded as a gap. Contingency training (CP-3) is not applicable because there is no workforce and no plan to train against. Contingency plan testing (CP-4) has not been performed and is recorded as a gap. System backup (CP-9) is provided by the platform, with the absence of an independent backup and a tested restore recorded as a gap. System recovery and reconstitution (CP-10) is inherited from the platform, with the absence of a documented recovery procedure recorded as a gap.

Inherited Responsibilities

Platform availability, backup, and recovery for the compute and database tiers are provided by the managed backend and edge providers.

Known Limitations

No written contingency plan exists. The Owner runs no independent backup outside the platform and has not performed a test restoration, so recoverability is assumed but unverified. These are the most material availability weaknesses for the system and are recorded in the System Security Plan.

Coordination, Compliance, and Review

Backup and recovery are shared with the managed backend provider. The Owner monitors compliance by confirming that backups are present. This policy is reviewed at least annually and after any change to the backup arrangement or the hosting model.

IA - Identification and Authentication Policy

Purpose and Scope

This policy governs how end users and the Owner are identified and authenticated to Community Tech Aid and to the platforms that operate it. It covers user registration and login, account recovery, password requirements, session re-authentication, and administrative authentication. It applies to the whole authorization boundary.

Authority, Management Commitment, and Designated Official

The Owner is the designated official for this policy, defines and maintains the authentication configuration, and holds the administrative credentials.

Roles and Responsibilities

The Owner configures authentication and protects administrative access. End users manage their own account credentials. Password storage, hashing, and lockout behavior are the responsibility of the managed authentication service.

Policy Statements

End users are uniquely identified by email address and authenticated with a password through the managed authentication service before any gated functionality is available. Anonymous sign-in is disabled. At registration, the application requires a minimum password length of 12 characters, a confirmation field, and a check of the password against a known-breached-password service, so that credentials known to be compromised are refused. Account recovery uses an emailed magic link. Password storage and hashing are performed by the managed authentication service. Administrative identification and authentication use provider accounts with multifactor authentication enabled on all administrative provider accounts. Sessions require re-authentication after a defined period of inactivity.

Procedures

Registration enforces the password rules above and rejects known-breached passwords. Recovery is performed by emailed magic link. Idle timeouts sign the user out and require re-authentication. Administrative sign-in uses provider accounts protected by multifactor authentication.

Control Family Coverage

This policy governs the LOW-baseline identification and authentication controls as follows. Identification and authentication of organizational users (IA-2), which for this business is the Owner, uses provider accounts with multifactor authentication. Identifier management (IA-4) uses unique email identifiers tied to the account record. Authenticator management (IA-5) covers the registration password rules, magic-link recovery, and provider-managed hashing, with the length rule now enforced server-side via a signup edge function and a residual on the raw signup endpoint. Authentication feedback (IA-6) uses masked input. Cryptographic module authentication (IA-7) is inherited from the providers. Identification and authentication of non-organizational users (IA-8), the end users, requires authentication with anonymous sign-in disabled. Re-authentication (IA-11) is enforced by idle timeouts.

Inherited Responsibilities

Password hashing and storage, the cryptographic modules, and the lockout behavior for repeated failures are provided by the managed authentication service and cannot be configured by the Owner.

Known Limitations

The 12-character minimum password length is now enforced server-side through a signup edge function, and the breached-password check runs both there and natively in the auth service. One residual remains: the managed backend platform exposes no "before user created" hook, so the raw signup endpoint can still be called directly with the anon key and is not subject to the length rule (the breached-password check still applies there). This residual is recorded in the System Security Plan.

Coordination, Compliance, and Review

Authentication is shared with the managed authentication service, which provides the mechanism, hashing, and lockout behavior. The Owner monitors compliance by operating the registration and login flows. This policy is reviewed at least annually and after any change to the authentication configuration.

IR - Incident Response Policy

Purpose and Scope

This policy governs how security incidents affecting Community Tech Aid are detected, handled, corrected, and reported. It applies to the whole authorization boundary and to incidents that involve the external providers the system depends on.

Authority, Management Commitment, and Designated Official

The Owner is the designated official for this policy and the sole responder. There is no incident response team and no external responder on retainer.

Roles and Responsibilities

The Owner detects, investigates, contains, corrects, and reports incidents, and decides whether notification to affected users or providers is warranted. Provider support channels are used when an incident involves a provider platform.

Policy Statements

When the Owner becomes aware of a security incident, the Owner investigates it using the available application and edge telemetry, contains it, corrects the underlying weakness, and records the finding and its remediation in the System Security Plan. The Owner decides, based on the nature of the incident, whether users or providers must be notified. The Owner uses provider support channels when an incident involves a provider platform. The one recorded incident to date, a client-side trust weakness in the access gate, was detected during review and corrected the same day, and is documented in the Findings section of the System Security Plan as a worked detect-and-correct example.

Procedures

On becoming aware of an incident, the Owner investigates using application and edge telemetry, applies a correction through the build environment, records the finding and its remediation in the System Security Plan, and determines whether notification is required.

Control Family Coverage

This policy governs the LOW-baseline incident response controls as follows. Incident response training (IR-2) is not applicable because there is no workforce. Incident handling (IR-4) is performed ad hoc, without a defined phased procedure, and is recorded as a gap. Incident monitoring (IR-5) has no dedicated tooling and is recorded as a gap. Incident reporting (IR-6) has no defined procedure and is recorded as a gap. Incident response assistance (IR-7) relies on provider support channels. Incident response plan (IR-8) is not maintained as a written phased plan and is recorded as a gap. This policy establishes the Owner's responsibility to respond; it does not by itself constitute the detailed incident response plan required by IR-8, which remains outstanding.

Known Limitations

There is no written, phased incident response plan with defined containment, eradication, and recovery steps, no incident-specific alerting or monitoring, and no documented breach-notification procedure to affected users. These are recorded in the System Security Plan.

Coordination, Compliance, and Review

Incident support is shared with the provider support channels. The Owner monitors compliance by recording incidents and their handling. This policy is reviewed at least annually and after any incident.

MA - Maintenance Policy

Purpose and Scope

This policy governs maintenance of Community Tech Aid, covering both the application maintenance the Owner performs and the platform maintenance performed by providers. It applies to the whole authorization boundary.

Authority, Management Commitment, and Designated Official

The Owner is the designated official for this policy and performs all application maintenance.

Roles and Responsibilities

The Owner maintains the application. Infrastructure maintenance is the responsibility of the managed backend and edge providers.

Policy Statements

Infrastructure maintenance, including host patching, database engine updates, and runtime maintenance, is performed by the managed backend and edge providers on their schedules and is not controlled by the Owner. Application-level maintenance is performed by the Owner remotely, over authenticated and encrypted provider consoles, with multifactor authentication enabled on all administrative provider accounts. The Owner is the only person who performs application maintenance, so maintenance access is inherently limited to one identity.

Procedures

The Owner makes application maintenance changes through the build environment over authenticated consoles. Platform maintenance occurs automatically under provider management and requires no Owner action.

Control Family Coverage

This policy governs the LOW-baseline maintenance controls as follows. Controlled maintenance (MA-2) separates inherited infrastructure maintenance from owner-performed application maintenance. Nonlocal maintenance (MA-4) is performed remotely over authenticated consoles protected by multifactor authentication. Maintenance personnel (MA-5) are the Owner for the application and provider-employed staff for the infrastructure.

Inherited Responsibilities

Host patching, database engine updates, and runtime maintenance are performed by the providers and cannot be scheduled, observed, or verified by the Owner.

Known Limitations

Because the backend is a managed platform the Owner does not own, the Owner cannot schedule or verify most infrastructure maintenance and relies on the providers for it. This is a property of the hosting model and is disclosed in the System Security Plan.

Coordination, Compliance, and Review

Maintenance is shared with the managed backend and edge providers. The Owner monitors compliance by operating application maintenance directly. This policy is reviewed at least annually and after any change of provider or hosting model.

MP - Media Protection Policy

Purpose and Scope

This policy governs the protection of media that stores Community Tech Aid data, in transit and at rest, throughout its life to disposal. It applies to the whole authorization boundary and reflects that the system holds no owner-controlled physical media.

Authority, Management Commitment, and Designated Official

The Owner is the designated official for this policy and is responsible for the logical handling of application data.

Roles and Responsibilities

The Owner controls the creation, retention, and logical deletion of application data. Physical media protection, handling, and sanitization are the responsibility of the managed backend provider and its data centers.

Policy Statements

The system uses no removable or physical media, and the Owner holds no media that stores system data. All data resides on managed cloud storage under the backend provider, where physical media access, handling, and sanitization at end of life are controlled by the provider and its data centers. Deletion of application data is logical, performed through the database. There is no media to label, store, transport, or physically destroy.

Procedures

Application data is created, retained, and deleted logically through the database. No removable media is provisioned, used, or transported.

Control Family Coverage

This policy governs the LOW-baseline media controls as follows. Media access (MP-2) is inherited because all storage is managed and there is no owner-held media. Media sanitization (MP-6) is performed by the provider's data-center processes at end of life, with application data deletion performed logically. Media use (MP-7) is not applicable because no removable media exists in the system.

Inherited Responsibilities

Physical media access control and sanitization are provided by the managed backend provider and its data centers and cannot be observed or verified by the Owner.

Known Limitations

Physical media protection cannot be inspected by the Owner because storage is a managed service. The Owner relies on the backend provider for it, as disclosed in the System Security Plan.

Coordination, Compliance, and Review

Physical media protection is inherited from the managed backend provider. The Owner monitors compliance by confirming the architecture uses no owner-held media. This policy is reviewed at least annually and after any change to the storage model.

PE - Physical and Environmental Protection Policy

Purpose and Scope

This policy governs physical and environmental protection of the infrastructure that hosts Community Tech Aid. It applies to the hosting infrastructure used by the managed backend and edge providers and states the inheritance position for a system with no owned facility.

Authority, Management Commitment, and Designated Official

The Owner is the designated official for this policy. The Owner operates no facility and commits to identifying the inheritance position accurately and obtaining provider attestations if required.

Roles and Responsibilities

Physical and environmental protection is the responsibility of the data-center operators used by the managed backend provider and the edge provider. The Owner operates no data center, server room, or owned hardware.

Policy Statements

eBiz Market, LLC operates no data center, server room, or owned facility that houses the system. Physical access authorization and control, physical access monitoring, visitor records, emergency power and lighting, fire detection and suppression, temperature and humidity controls, and water damage protection for the hosting infrastructure are provided and controlled by the data-center operators used by the providers. The Owner inherits these controls and does not implement, configure, or inspect them. The system uses no organization-controlled physical output devices.

Procedures

There are no owner-performed physical or environmental procedures. The Owner's responsibility is limited to identifying the inheritance position accurately in the System Security Plan and, if third-party attestation is required, requesting provider compliance reports.

Control Family Coverage

This policy governs the LOW-baseline physical controls as inherited from the providers' data-center operators: physical access authorizations (PE-2), physical access control (PE-3), access control for transmission (PE-4), monitoring physical access (PE-6), visitor access records (PE-8), emergency lighting (PE-12), fire protection (PE-13), environmental controls (PE-14), water damage protection (PE-15), and delivery and removal (PE-16). Access control for output devices (PE-5) is not applicable because the system uses none. PE-7 is withdrawn in Rev 5 and incorporated into PE-2 and PE-3.

Inherited Responsibilities

All physical and environmental controls for the hosting infrastructure are provided by the providers and their data-center operators.

Known Limitations

The Owner cannot inspect the hosting facilities and does not currently hold provider facility audit reports. If third-party attestation of these inherited controls is required, obtaining provider compliance reports is recorded as an owner-input item in the System Security Plan.

Coordination, Compliance, and Review

These controls are inherited from the providers and their data-center operators. The Owner monitors compliance by confirming that no owned facility exists. This policy is reviewed at least annually and would be rewritten if the business ever operated its own facility or hardware.

PL - Planning Policy

Purpose and Scope

This policy governs security planning for Community Tech Aid, including maintenance of the System Security Plan, selection and tailoring of the control baseline, and the rules of behavior presented to users. It applies to the whole authorization boundary.

Authority, Management Commitment, and Designated Official

The Owner is the designated official for this policy, develops and maintains the System Security Plan, and selects and tailors the control baseline.

Roles and Responsibilities

The Owner performs all planning functions. Rules of behavior for end users are published and accepted by users; there are no internal staff rules of behavior because there are no staff.

Policy Statements

The system maintains a System Security Plan that describes the authorization boundary, the data types and personal information handled, the data flows, the customer responsibility matrix, and the implementation of each applicable control. The Owner has selected the NIST SP 800-53 Rev 5 LOW baseline as the applicable control set, consistent with the LOW security categorization, and tailors that baseline to the system by marking controls that do not apply with stated reasons and by reflecting the single-operator reality in the personnel and awareness families. Rules of behavior for end users are published as the Terms of Service and accepted as a condition of use.

Procedures

The Owner updates the System Security Plan when the system changes and records tailoring decisions per control within it. Public Terms of Service state the rules of behavior for users.

Control Family Coverage

This policy governs the LOW-baseline planning controls as follows. System security and privacy plans (PL-2) are met by the maintained System Security Plan, with a separate formal privacy plan not maintained though a public Privacy Policy is live. Rules of behavior (PL-4) are published as the Terms of Service for end

users. Baseline selection (PL-10) is the LOW baseline. Baseline tailoring (PL-11) is performed per control in the System Security Plan.

Known Limitations

A separate, formal privacy plan is not maintained, although a public Privacy Policy is live, and there are no internal rules of behavior because there are no staff.

Coordination, Compliance, and Review

Planning is internal to the Owner. Compliance is monitored by keeping the System Security Plan current. This policy is reviewed at least annually and after any significant change to the boundary or baseline.

PS - Personnel Security Policy

Purpose and Scope

This policy governs personnel security for Community Tech Aid. Its scope is matched to a business with a single principal and no employees, and it also addresses access granted to any external collaborator.

Authority, Management Commitment, and Designated Official

The Owner is the designated official for this policy and is the sole principal of the LLC and the entire workforce.

Roles and Responsibilities

The Owner holds all responsibility for the system. Where a collaborator is granted an account, the Owner is responsible for ensuring that access is appropriate and agreement-backed if warranted. Personnel security for provider staff is the providers' responsibility.

Policy Statements

eBiz Market, LLC has no employees, contractors, or staff. There are therefore no positions to risk-designate, no personnel to screen, no termination or transfer process, no sanctions process, and no position descriptions to maintain. Where a marketing collaborator has been granted an account, the Owner is responsible for ensuring that the access is appropriate and for putting a written access or confidentiality agreement in place if one is warranted. Personnel security for the providers that operate the platforms is the providers' responsibility under their own programs, and the Owner relies on their terms of service.

Procedures

The Owner grants access only to the Owner and, where justified, a single named collaborator, and periodically confirms that the collaborator's access remains appropriate.

Control Family Coverage

This policy governs the LOW-baseline personnel controls as follows. Position risk designation (PS-2), personnel screening (PS-3), personnel termination (PS-4), personnel transfer (PS-5), personnel sanctions (PS-8), and position descriptions (PS-9) are not applicable because there is no workforce. Access agreements (PS-6) are the Owner's responsibility, with the collaborator agreement recorded as an owner-input item. External personnel security (PS-7) is inherited from the providers.

Known Limitations

Whether a written access or confidentiality agreement covers the marketing collaborator is recorded as an owner-input item in the System Security Plan. If the business adds staff, this policy must be rewritten to add real screening, agreements, and separation procedures.

Coordination, Compliance, and Review

Provider personnel security is inherited from the providers. The Owner monitors compliance by keeping the number of accounts minimal and known. This policy is reviewed at least annually and whenever a person other than the Owner is granted access.

RA - Risk Assessment Policy

Purpose and Scope

This policy governs how security risk to Community Tech Aid is categorized, assessed, and responded to, including vulnerability monitoring. It applies to the whole authorization boundary.

Authority, Management Commitment, and Designated Official

The Owner is the designated official for this policy and performs security categorization, risk assessment, and risk response.

Roles and Responsibilities

The Owner identifies and responds to risks and records open risks in the System Security Plan. Vulnerability management of the underlying platform is the responsibility of the managed backend and edge providers.

Policy Statements

The Owner categorizes the system as LOW for confidentiality, integrity, and availability, based on the nature of the data and the consumer service. The Owner identifies and responds to risks as they are found and records open risks in the System Security Plan. At registration the application checks passwords against a known-breached-password service, which reduces credential risk. Vulnerability management of the underlying platform is performed by the managed backend and edge providers, and the Owner relies on that inherited patching.

Procedures

The Owner records the categorization and open risks in the System Security Plan and applies corrections through the build environment when risks are

identified, as shown by the documented same-day remediation of the access-gate weakness.

Control Family Coverage

This policy governs the LOW-baseline risk controls as follows. Security categorization (RA-2) is the owner-asserted LOW rating, with the absence of a formal, documented categorization exercise recorded as a gap. Risk assessment (RA-3) is informal, with no formal assessment recorded as a gap. Vulnerability monitoring and scanning (RA-5) relies on inherited platform patching and the breached-password check, with the absence of owner-run application scanning recorded as a gap. Risk response (RA-7) is ad hoc.

Inherited Responsibilities

Vulnerability management and patching of the managed platform are performed by the providers.

Known Limitations

The LOW categorization is asserted rather than produced through a formal, documented exercise, and no formal risk assessment with likelihood and impact ratings exists. Dependency vulnerability scanning is now in place and was acted on during the 2026-07-28 remediation, but there is no application dynamic or penetration scan beyond that and the inherited platform patching. These are recorded in the System Security Plan.

Coordination, Compliance, and Review

Platform vulnerability management is shared with the providers. The Owner monitors compliance by maintaining the risk information in the System Security Plan. This policy is reviewed at least annually and after any significant change to the system or its risk profile.

SA - System and Services Acquisition Policy

Purpose and Scope

This policy governs how Community Tech Aid acquires and relies on the platforms, services, and components that make up the system, and how security is considered in its development. It applies to the whole authorization boundary.

Authority, Management Commitment, and Designated Official

The Owner is the designated official for this policy, selects and funds the services the system depends on, and develops and maintains the application.

Roles and Responsibilities

The Owner performs all acquisition and development functions. Security of the acquired services is the responsibility of the providers under their terms.

Policy Statements

The Owner allocates the funds required to operate the platforms and services the system depends on. Services are acquired from established providers through their official channels under their standard commercial terms. Security engineering principles are applied in the build, including enforcing the free-message allowance on the server before any paid downstream call, confining the AI provider API key to a server-side function, restricting each user to their own data with Row Level Security, restricting analytics requests to allowed origins, restricting authentication redirects to an allowlist, and disabling anonymous sign-in. The Owner maintains the System Security Plan as the primary system documentation.

Procedures

The Owner subscribes to the required services through official channels, applies the engineering principles above during development, and records the component set and interconnections in the System Security Plan.

Control Family Coverage

This policy governs the LOW-baseline acquisition controls as follows. Allocation of resources (SA-2) is the Owner's funding of the services. System development life cycle (SA-3) is an informal iterative lifecycle, recorded as a gap where a documented lifecycle with security gates is expected. Acquisition process (SA-4) accepts provider standard terms. System documentation (SA-5) is the System Security Plan plus provider documentation. Security and privacy engineering principles (SA-8) are applied in the build. External system services (SA-9) are governed by documenting reliance under provider terms. Unsupported system components (SA-22) relies on current supported services, with the absence of formal dependency end-of-support tracking recorded as a gap.

Known Limitations

Development follows an informal, iterative lifecycle rather than a documented life cycle with defined security gates, the Owner accepts providers' standard terms rather than negotiating custom security requirements, and the Owner maintains no formal process to track end-of-support dates for application dependencies. These are recorded in the System Security Plan.

Coordination, Compliance, and Review

Acquisition and external services are shared with the providers. The Owner monitors compliance by maintaining the component inventory. This policy is reviewed at least annually and after any change of provider or major dependency.

SC - System and Communications Protection Policy

Purpose and Scope

This policy governs protection of Community Tech Aid communications and the separation and protection of its data in transit and at rest. It applies to the whole authorization boundary and distinguishes the application-layer protections the Owner controls from the transport, edge, cryptographic, and isolation protections inherited from providers.

Authority, Management Commitment, and Designated Official

The Owner is the designated official for this policy and configures the application-layer protections within the Owner's control.

Roles and Responsibilities

The Owner maintains the application-layer boundary settings. Transport encryption, edge protection, DNS integrity, cryptographic modules, and platform isolation are provided by the edge and backend providers.

Policy Statements

All traffic to the system is served over encrypted transport, terminated at the edge provider, and connections to external services use encrypted transport. Denial-of-service protection is provided at the edge, and the application adds a server-side per-account message cap that bounds use of the paid downstream call. Application boundary protection is implemented through route gating, disabled anonymous sign-in, the analytics origin allowlist, the authentication redirect allowlist, and server-side validation of paid access. Application data at rest is stored in the managed database, where encryption at rest is provided by the platform, and access to it is further restricted by Row Level Security. Cryptographic keys and modules for transport, token signing, and password hashing are established and managed by the providers. Application secrets are held in the platform secret store.

Procedures

The Owner maintains the application-layer boundary settings in their known-good state and relies on the providers for transport encryption, edge protection, DNS, cryptography, and process isolation.

Control Family Coverage

This policy governs the LOW-baseline communications controls as follows. Denial-of-service protection (SC-5) is inherited at the edge and supplemented by the application usage cap. Boundary protection (SC-7) combines inherited network edge protection with the application-layer boundary settings. Transmission confidentiality and integrity (SC-8) is encrypted transport. Cryptographic key establishment and management (SC-12) and cryptographic protection (SC-13) are inherited. Collaborative computing devices (SC-15) are not applicable. The name and address resolution controls (SC-20, SC-21, SC-22) are inherited from the DNS provider, with DNSSEC enablement recorded as an owner-input item and no owner-operated recursive resolver. Protection of information at rest (SC-28) is platform encryption plus Row Level Security. Process isolation (SC-39) is inherited.

Inherited Responsibilities

Cipher configuration, certificate management, cryptographic module selection, DNS infrastructure, and process isolation are provided by the edge and backend providers and cannot be configured by the Owner.

Known Limitations

The Owner cannot configure the inherited cryptography, DNS infrastructure, or isolation, cannot independently verify encryption at rest because there is no direct database access, and has not confirmed whether DNSSEC is enabled for the primary domain. These are recorded in the System Security Plan.

Coordination, Compliance, and Review

These protections are shared with the edge and backend providers. The Owner monitors compliance by maintaining the application-layer settings. This policy is reviewed at least annually and after any change to the boundary or providers.

SI - System and Information Integrity Policy

Purpose and Scope

This policy governs the integrity of Community Tech Aid, including flaw remediation, protection against malicious input, system monitoring, and information retention. It applies to the whole authorization boundary.

Authority, Management Commitment, and Designated Official

The Owner is the designated official for this policy, remediates application flaws, maintains the input-abuse protections, and manages information retention.

Roles and Responsibilities

The Owner performs application flaw remediation and maintains the integrity protections. Platform flaw remediation is the responsibility of the providers.

Policy Statements

The Owner remediates application flaws through the build environment, as shown by the documented same-day correction of the access-gate weakness. Platform and infrastructure flaws are remediated by the providers. The application accepts text input rather than file uploads or executable content, which limits malicious-code exposure, and it records spam attempts and maintains a suppression list. Retention is scheduled by daily database jobs: authentication events at 90 days, and chat sessions, contact messages, and demographics submissions at 180 days. The Owner receives security advisories through provider notifications.

Procedures

The Owner applies application corrections as flaws are found and relies on the providers for platform patching. The suppression list and spam-attempt records are maintained by the application. The 90-day authentication-event purge runs automatically.

Control Family Coverage

This policy governs the LOW-baseline integrity controls as follows. Flaw remediation (SI-2) combines owner application remediation with inherited platform patching, with no scheduled patch cycle on the owner side recorded as a gap. Malicious code protection (SI-3) relies on text-only input, spam and suppression tracking, and inherited infrastructure protection. System monitoring (SI-4) is limited to inherited edge analytics and application tables, with no alerting recorded as a gap. Security alerts and advisories (SI-5) are received informally through provider notifications, with no formal process recorded as a gap. Information management and retention (SI-12) defines a 90-day purge for authentication events, with no documented schedule for chat content and form submissions recorded as a gap.

Inherited Responsibilities

Platform and infrastructure flaw remediation and endpoint protection are performed by the providers.

Known Limitations

Dependency vulnerabilities are now scanned and were remediated on 2026-07-28 (residuals with no upstream fix are monitored), monitoring now includes defined alert triggers, and retention and disposal are now scheduled for all owner-controlled personal-data tables. What remains: no fixed scheduled patch cadence, no SIEM or dashboard beyond the defined alerts, and no formal process to receive and act on security advisories. These are recorded in the System Security Plan.

Coordination, Compliance, and Review

Flaw remediation and monitoring are shared with the providers. The Owner monitors compliance by operating the application and its integrity protections. This policy is reviewed at least annually and after any significant change to the application or its data types.

SR - Supply Chain Risk Management Policy

Purpose and Scope

This policy governs how Community Tech Aid manages risk arising from the providers and components it depends on. It applies to the whole authorization boundary and to the provider set named in the System Security Plan.

Authority, Management Commitment, and Designated Official

The Owner is the designated official for this policy, selects the providers and components, and is responsible for keeping the dependency set small, known, and sourced from authentic channels.

Roles and Responsibilities

The Owner selects and documents the dependency set. Supply chain security within each provider is the provider's responsibility.

Policy Statements

The system depends on a small set of established providers, each acquired directly through the provider's official channels, which supports component authenticity. The Owner keeps the dependency set documented in the System Security Plan. The Owner relies on the providers' standard breach and incident notification practices as stated in their terms of service. Disposal of physical components is handled by the providers under their data-center processes; the Owner disposes of no physical components and performs disposal of application data logically.

Procedures

The Owner records the provider and component set in the System Security Plan and sources all services from official provider channels. Logical cleanup of unused elements is performed through the relevant provider console.

Control Family Coverage

This policy governs the LOW-baseline supply chain controls as follows. Supply chain risk management plan (SR-2) is not maintained as a formal plan and is recorded as a gap. Supply chain controls and processes (SR-3) are largely inherited from the providers, with the Owner keeping the dependency set small. Acquisition strategies (SR-5) consist of selecting known providers. Notification agreements (SR-8) rely on provider standard terms. Inspection of systems or components (SR-10) cannot be performed by the Owner because there is no direct access, and is inherited. Component authenticity (SR-11) is supported by sourcing through official channels. Component disposal (SR-12) is inherited for physical components and logical for application data, with two candidate cleanup items recorded as owner input.

Inherited Responsibilities

Supply chain security within each provider, physical component disposal, and the integrity of the managed components are the providers' responsibility.

Known Limitations

No formal supply chain risk management plan exists, the Owner performs no independent inspection of the managed components because there is no direct access, and there are no custom notification agreements beyond provider terms. Two candidate cleanup items, an edge worker with no recorded invocations and the non-primary domains, are recorded as owner-input items in the System Security Plan.

Coordination, Compliance, and Review

Supply chain controls are largely inherited from the providers. The Owner monitors compliance by keeping the dependency set minimal and documented. This policy is reviewed at least annually and after any change of provider or major component.

End of policy manual. Eighteen family policies, version 1.0, effective 2026-07-27. Each policy satisfies its family "-1" control: purpose and scope, roles and responsibilities, management commitment, coordination, compliance, procedures, a designated official, and a defined review cadence of at least annually and following any significant system change. Control family titles verified against the NIST SP 800-53 Rev 5 catalog. This manual describes the system as it exists and names its gaps.